

PSC Accreditation Checklist – EA-103

v2.1

Based on: Guia de Evaluacion EA-103 v2.1 (08/02/2013), Subsecretaria de Economia y Empresas de Menor Tamano, Ministerio de Economia, Fomento y Turismo, Gobierno de Chile.

Applicable law: Ley N 19.799 sobre Documentos Electronicos, Firma Electronica y Servicios de Certificacion. Regulation: Decreto Supremo N 181 (2002, modified 2012).

Evaluation scale per the guide: - **A** – Full compliance - **A-** – Non-compliance is subsanable and does not affect system operation - **B** – Non-compliance is not subsanable or affects system operation (application rejected)

Summary

ID	Name	Status	Blocking Dependencies
AS01	Requisitos de Admisibilidad	:x: Missing	None
RG01	Requerimientos Generales	:x: Missing	AS01
LE01	Aspectos Legales y de Privacidad	:x: Missing	None
TB01	Estructura Certificados	:x: Missing	None
TB02	Estructura CRL y Servicio OCSP	:warning: Partial	TB01
TB03	Registro de Acceso Publico	:warning: Partial	None
TB04	Modelo de Confianza y TSL	:x: Missing	TB01
PS01	Revision de Riesgos y Amenazas	:x: Missing	None

ID	Name	Status	Blocking Dependencies
PS02	Politica de Seguridad	:x: Missing	PS01
PS03	Plan de Continuidad del Negocio	:warning: Partial	PS02
PS04	Plan de Seguridad de Sistema	:x: Missing	PS02
PS05	Implementacion del Plan de Seguridad	:x: Missing	PS04
PS06	Plan de Administracion de Llaves	:warning: Partial	PS02, PS04
PS07	Gestion de Incidentes de Seguridad	:warning: Partial	PS01
ET01	Evaluacion de la Plataforma Tecnologica	:x: Missing	TB01-TB04, PS02, PS03, PS04, PS05
SF01	Seguridad Fisica	:x: Missing	PS02
PO01	Politica de Certificados de FEA	:x: Missing	PS03, PS05, PS06, ET01, SF01
PO02	Declaracion de Practicas de Certificacion (CPS)	:warning: Partial	PO01, AD01, AD02, PE02
PO03	Modelo Operacional de la AC	:x: Missing	PO02
PO04	Modelo Operacional de la AR	:x: Missing	PO03
AD01	Manual de Operaciones de la AC	:x: Missing	PS04
AD02	Manual de Operaciones de la AR	:x: Missing	PS04
PE01	Examen del Personal	:x: Missing	PS02
PE02	Examen del Personal – Oficial de Seguridad	:x: Missing	PS02

Overall readiness: 0/24 fully compliant. 6/24 partial. 18/24 missing entirely.

Requirement Details

AS01 – Requisitos de Admisibilidad

Class: Admisibilidad **Dependency:** None **Standards:** N/A (Ley N 19.799 Art. 12 f) y 18; Reglamento Art. 2, 18)

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Entrega de documentacion solicitada	All documentation specified in the guide must be delivered at the time of application. Content is not evaluated at this stage.
Comprobante de pago del arancel	Payment receipt for 798 UF accreditation fee issued by Ministerio de Economia, Fomento y Turismo.

Documentation required:

- Solicitud de acreditacion with PSC identification data:
 - 1. Nombre o razon social de la empresa solicitante
 - 1. RUT de la empresa solicitante
 - 1. Nombre del representante legal
 - 1. RUT del representante legal
 - 1. Domicilio social
 - 1. Direccion de correo electronico
- Copia de contratos de servicios externalizados (if any)
- Procedimientos para asegurar acceso a peritos (Reglamento Art. 14)
- All documentation specified in every other requirement section of the guide

Evidence required: Comprobante de pago del arancel de acreditacion.

Goya Ledger status: :x: Missing

What needs to be done:

1. Constitute a SpA chilena (Sociedad por Acciones) or register a Chilean branch of the Estonian entity. Obtain RUT from SII.
2. Appoint a representante legal with Chilean RUT.
3. Establish domicilio social in Chile.
4. Budget 798 UF (approximately CLP \$28M / USD \$30K at current UF value) for the accreditation fee.
5. Prepare the formal solicitud de acreditacion letter with all identification fields.
6. Compile the full documentation package for all 24 requirements before submitting.
7. If services are externalized (Fly.io hosting, etc.), prepare copies of those contracts.

RG01 – Requerimientos Generales

Class: Requerimientos Generales **Dependency:** AS01 **Standards:** N/A (Ley N 19.799 Art. 14, 17 e), 18, 20, 23 inciso 10; Reglamento Art. 12, 16 e), 17)

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Procedimiento	Compliance with procedures and deadlines defined by the Entidad Acreditadora.
Acceso	Free access to auditors/experts sent by the Entidad Acreditadora during accreditation or on-site audits.
Informacion	Delivery of any additional information requested by the Entidad Acreditadora through identified experts.
Poliza de seguro de responsabilidad civil	The PSC must present a civil liability insurance policy per Reglamento Art. 12 within 20 days after the favorable evaluation. Minimum coverage: 5,000 UF (approx. CLP \$175M / USD \$180K).

Documentation required:

- Procedimiento interno para inspeccion de la Entidad Acreditadora
- Poliza de seguro vigente

Goya Ledger status: :x: Missing

What needs to be done:

1. Draft an internal procedure document for Entidad Acreditadora inspections: who receives auditors, how to provide access to systems/facilities, response SLAs.
 2. Identify an insurance broker in Chile that offers polizas de responsabilidad civil for PSC operations.
 3. Obtain a quote for a civil liability policy of at least 5,000 UF. This policy is presented after favorable evaluation (within 20 days), not at application time.
 4. Designate a contact person for Entidad Acreditadora communications.
-

LE01 – Aspectos Legales y de Privacidad

Class: Legales **Dependency:** None **Standards:** Ley N 19.628 (Proteccion de la Vida Privada), Ley N 19.799, Ley N 19.496 (Proteccion del Consumidor)

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Personalidad Juridica	Validity and currency of the legal entity, verified via escritura and certificates.

Aspect	Evaluation
Domicilio	Chilean domicile verified via RUT and documents proving activity in Chile.
Giro de la empresa	Business purpose compatible with PSC activity.
Capital	Sufficient financial backing to ensure permanence and responsibility to certificate holders. Capital social registered with SII is the reference.
Privacidad de la Informacion	Privacy clauses in subscriber contracts defining PSC responsibility for data protection.
Practicas no discriminatorias	CP, CPS, and contracts free of discriminatory clauses.
Publicidad y servicios no contratados	No forced bundling of unwanted services with FEA certificates.
Concordancia con Ley N 19.496	Adhesion contracts must not contradict consumer protection law.
Concordancia con Ley N 19.628	Adhesion contracts must not contradict data protection law.
Evaluacion de Privacidad del Sitio Web	Website compliant with privacy standards and Ley N 19.628.

Documentation required:

1. Copia autorizada ante notario de la cedula RUT de la entidad solicitante
2. Copia fiel de la escritura de constitucion de la sociedad, inscrita y publicada, con vigencia
3. Poderes de los representantes legales (if not in estatutos sociales)
4. Iniciacion de actividades en SII
5. Ultimo balance auditado de la persona juridica
6. Documento de la Politica de Privacidad

Evidence required: Proof of Chilean domicile, certificado del registro de comercio, informe de evaluacion de privacidad del sitio web.

Goya Ledger status: :x: Missing

What needs to be done:

1. Constitute a Chilean SpA or register a branch (sucursal) of the Estonian entity in Chile. The guide says “persona juridica constituida segun la legislacion vigente en Chile o en el pais que corresponda y que tiene domicilio en Chile.”
2. Register at SII (Servicio de Impuestos Internos) with a giro compatible with certification services.
3. Produce an audited financial statement (balance auditado).
4. Write a formal Privacy Policy document (Politica de Privacidad) compliant with Ley N 19.628.
5. Draft subscriber adhesion contracts with privacy clauses, consumer protection compliance, and non-discrimination provisions.
6. Conduct a privacy evaluation of the public website.

7. Ensure the website publishes the privacy policy prominently.

TB01 – Estructura Certificados

Class: Tecnico Basico **Dependency:** None **Standards:** ISO/IEC 9594-8, ITU-T X.690

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Conformidad con el estandar ISO/IEC 9594-8	Certificate basic structure conforms to X.509v3, grammar in basic structure and mandatory extensions allows RUT inclusion and is readable by any compliant application.
Contenido basico del certificado FEA	Must contain: (a) unique certificate ID, (b) PSC identification with razon social, RUT, email, accreditation data, own FEA signature, (c) holder identity with name, email, RUT, (d) validity period.
Metodo de incorporacion del RUT	PSC and holder RUT incorporated per the Reglamento-specified structure and identifiers.
Lectura y reconocimiento del contenido minimo	Additional attributes must not impede reading of mandatory fields per Reglamento Art. 28.
Reconocimiento de limites de uso	Usage limits in the certificate must be recognizable by third parties.
Uso de clave publica acreditada	Signing keys used for FEA certificates must not be used for certificates under other policies.
Algoritmos de firma	Industry-standard signature algorithms providing adequate security for both PSC and holder signatures.
Largos de llaves	Key lengths providing industry-standard security level for both PSC and holder.
Funciones Hash	Industry-standard hash functions for the signing process.

Documentation required: None (evaluated via certificate sample).

Evidence required: Sample FEA certificate issued by the PSC (binary format) and the CA certificate of the issuing CA (binary format).

Goya Ledger status: :x: Missing

What needs to be done:

1. **Implement X.509v3 certificate issuance.** Goya currently uses DID + SD-JWT Verifiable Credentials, not X.509 certificates. The Chilean PSC framework mandates X.509v3 certificates per ISO/IEC 9594-8. This is a fundamental architectural gap.

2. Build a Certificate Authority (CA) module capable of:
 - Generating X.509v3 certificates with all mandatory fields
 - Including RUT in the certificate per Reglamento-specified OID structure
 - Including the text “Certificado para firma electronica avanzada” in the Certificate Policies extension
 - Signing certificates with the CA’s FEA key
 3. Define OID structure for the Goya CA certificate policy.
 4. Ensure the CA signing key is dedicated exclusively to FEA certificate issuance.
 5. Support RSA 2048+ or ECDSA P-256+ as minimum key lengths (industry standard). ML-DSA-65 can be offered as an additional algorithm but must not be the only option since the evaluator expects “industry-standard” algorithms.
 6. Use SHA-256 or SHA-384 as hash functions.
 7. Produce sample certificates in DER/PEM format for evaluator review.
-

TB02 – Estructura CRL y Servicio OCSP

Class: Tecnico Basico **Dependency:** TB01 **Standards:** ISO/IEC 9594-8, RFC 2560 (updated by RFC 6277), RFC 5280

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Contenido Minimo de CRL	Version (must be 2), signature algorithm identifier, issuer name, thisUpdate, nextUpdate, revoked certificates with serial numbers and revocation dates.
OCSP service	Implemented per RFC 2560 with Validation Request and Validation Response mechanisms.
Comprobacion de firma	CRL must be signed by the issuing CA.
Mecanismo de suspension de certificados	CRL must support certificate suspension status indication.
Peticion de Validacion y Respuesta	OCSP must implement validation request/response per RFC 2560/6277.

Documentation required: Politica de certificacion del certificado de firma electronica avanzada del PSC.

Evidence required: Sample CRL issued by the PSC (binary), CA certificate, OCSP responder response.

Goya Ledger status: :warning: Partial

- OCSP responder: Implemented (RFC 6960). Goya has an OCSP module.
- CRL: Not implemented. Goya uses a StatusList2021-style revocation mechanism, not X.509 CRL format per RFC 5280.

What needs to be done:

1. **Implement CRL generation** in X.509 CRL v2 format per RFC 5280:
 - Version field = 2

- Signed by the CA private key
 - Include thisUpdate and nextUpdate timestamps
 - List revoked certificate serial numbers with revocation dates
 - Support certificate suspension (certificateHold reason code)
 - Publish updated CRL at least every 24 hours
2. Verify the existing OCSP responder conforms to RFC 2560/6277 (not just RFC 6960). Ensure it handles validation request/response as expected by evaluators.
 3. Ensure OCSP responses are signed by the CA or a designated OCSP responder certificate.

TB03 – Registro de Acceso Publico

Class: Tecnico Basico **Dependency:** None **Standards:** N/A (Ley N 19.799 Art. 11, 12 letras b y d, 16, 17 letras b y d, 23 inciso 1; Reglamento Art. 2, 7, 16 b y d, 27, 28, 29, 30)

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Existencia y contenido minimo del sitio de informacion publica	Public website must contain: registry of issued certificates (ID, status), CRL updated every 24h, transfer indicators, secure access for revocation/suspension, CP document, CPS document, EA resolutions, OCSP service.
Disponibilidad de la informacion publica	Site availability must be at least 99%. Redundant/alternative connection mechanisms and emergency sites.
Seguridad	Integrity and availability of information protected via physical and logical security measures against internal and external attacks.

Documentation required: Descriptive document containing: site identification, technology description, availability/connectivity/diagrams, security measures.

Evidence required: Operational public access website with the described functionalities.

Goya Ledger status: :warning: Partial

- Goya has a deploy site at docs/deploy/ with HTML pages.
- CPS is published at docs/deploy/cps.html and docs/policy/CPS.md.
- Privacy policy published at docs/deploy/privacy.html.
- No public certificate registry with certificate status lookup.
- No CRL publication endpoint.
- No 99% SLA documentation for the public site.

What needs to be done:

1. Build a public certificate registry web interface showing: certificate ID, holder name (or pseudonym), status (vigente/revocado/suspendido), and transfer indicators.
2. Publish CRL on the website, updated every 24 hours.

3. Publish the CP and CPS documents on the website.
 4. Publish relevant EA resolutions.
 5. Provide secure authenticated access for certificate holders to request revocation/suspension.
 6. Document 99% uptime SLA with redundancy mechanisms (multi-region Fly.io deployment or equivalent).
 7. Implement HTTPS with TLS for all public endpoints.
 8. Write the descriptive document for the public access system.
-

TB04 – Modelo de Confianza y TSL

Class: Tecnico Basico **Dependency:** TB01 **Standards:** ETSI TS 102 231

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Modelo de confianza	Whether the adopted trust model meets the stated objective, enabling verification of any FEA certificate received.
Efectividad	Whether the mechanism used to implement the trust model works in practice.
TSL	Whether the TSL implementation conforms to ETSI TS 102 231.

Documentation required: Document describing the trust model used by the PSC. Alternatively, the CP document if it covers this topic. TSL information per ETSI TS 102 231.

Evidence required: TSL data conforming to ETSI TS 102 231.

Goya Ledger status: :x: Missing

What needs to be done:

1. Write a Trust Model document describing how certificate holders and relying parties can verify the validity of FEA certificates issued by Goya.
 2. Define the CA hierarchy (root CA, issuing CA, cross-certification if applicable).
 3. Implement TSL (Trusted Service List) generation per ETSI TS 102 231 format.
 4. Coordinate with the Entidad Acreditadora to be included in the national TSL once accredited.
 5. The trust model must explain how Goya's trust propagates through the Chilean PKI ecosystem.
-

PS01 – Revision de la Evaluacion de Riesgos y Amenazas

Class: Seguridad **Dependency:** None **Standards:** ISO 27001, ISO 27005, NIST SP 800-30

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Reporte de la valoracion de riesgos	Risks must be realistic, no relevant risks omitted, adequate risk valuation, maintenance plan for the assessment.
Estructura del proceso de Gestion de riesgos	Risk management process must be performed or audited by a qualified independent external entity.

Documentation required: Copy of the risk assessment document.

Goya Ledger status: :x: Missing

What needs to be done:

1. Conduct a formal risk assessment following ISO 27005 methodology:
 - Context establishment (objectives, scope, organization)
 - Risk identification (assets, threats, vulnerabilities)
 - Risk estimation (quantitative or qualitative)
 - Risk evaluation (against acceptance criteria)
 - Risk treatment (reduction, acceptance, avoidance, transfer)
 - Risk acceptance documentation
 - Risk communication plan
2. Cover all PKI-specific risks: CA key compromise, HSM failure, unauthorized certificate issuance, insider threats, denial of service, data breaches.
3. Have the risk assessment performed or audited by a qualified independent external entity.
4. Establish a risk assessment maintenance plan (periodic reviews).
5. Document residual risk levels after treatment.

PS02 – Politica de Seguridad

Class: Seguridad **Dependency:** PS01 **Standards:** ISO/IEC 27002 Section 5

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Conformidad con ISO 27002 seccion 5.1.1	Security policy requirements from section 5.1.1 incorporated.
Conformidad con ISO 27002 seccion 5.1.2	Periodic review and evaluation procedure for the security policy.
Consistencia entre la politica de seguridad y CPS	Security policy consistent with CPS.
Consistencia entre la politica de seguridad y la CP	Security policy consistent with the FEA Certificate Policy.
Relacion entre la Evaluacion de Riesgos y la politica de seguridad	Security policy aspects coherent with risk levels from the formal risk assessment.
Inclusion de las secciones atingentes	Fundamental security policy elements included per SANS Institute guidance.

Aspect	Evaluation
Claridad de los objetivos de seguridad	Clear, high-level, non-technical security objectives related to protecting business processes and services.

Documentation required: Copy of the organizational Information Security Policy document.

Evidence required: On-site audit to verify relevant aspects.

Goya Ledger status: :x: Missing

What needs to be done:

1. Write a formal Information Security Policy document following ISO 27002 Section 5 structure.
2. Ensure security objectives derive from the PS01 risk assessment.
3. Make the policy technology-neutral and high-level.
4. Include a periodic review procedure (at least annual).
5. Cross-reference security elements with both the CPS and CP documents.
6. Cover: scope, security objectives, management commitment, organizational structure for security, asset classification, incident management references, compliance references.
7. Have management formally approve and sign the policy.

PS03 – Plan de Continuidad del Negocio

Class: Seguridad **Dependency:** PS02, PO02 **Standards:** ISO 27002 Section 14, ETSI TS 102 042 Section 7.4.8, BS25999 / ISO 22301

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Conformidad con ISO 27002 seccion 14.1.1 al 14.1.4	BCP requirements from sections 14.1.1 through 14.1.4 incorporated.
Conformidad con ISO 27002 seccion 14.1.5	Periodic review and evaluation procedure for BCP.
Conformidad con ETSI TS 102 042 seccion 7.4.8	Detailed procedures for CA private key compromise per ETSI standard.
Relacion entre la Evaluacion de Riesgos y el BCP y DRP	BCP/DRP aspects coherent with risk levels from formal risk assessment.
Business Impact Analysis	BIA coherence as part of contingency management plan.
Viabilidad de las facilidades computacionales alternativas	Alternative computing facilities meet minimum requirements for PSC operation.
Elementos de auditoria	System provides mechanisms for preserving audit evidence.

Documentation required: Business Continuity Plan (BCP), Disaster Recovery Plan (DRP), Risk Assessment document.

Goya Ledger status: :warning: Partial

- Goya has docs/compliance/BUSINESS-CONTINUITY-DR.md with a BCP/DRP framework.
- Goya has docs/compliance/INCIDENT-RESPONSE-PLAN.md.
- No formal BIA (Business Impact Analysis) document.
- No specific procedure for CA private key compromise (since no CA exists yet).
- No documentation of alternative computing facilities.

What needs to be done:

1. Expand the existing BCP/DRP document to align with ISO 27002 Section 14 and BS25999/ISO 22301 structure.
2. Add a detailed procedure for CA private key compromise per ETSI TS 102 042 Section 7.4.8.
3. Write a formal Business Impact Analysis (BIA).
4. Document emergency procedures for at least: software disaster, security incident, CA private key compromise, audit mechanism failure, hardware failure (servers, HSMs, security devices, network devices).
5. Document alternative computing facilities and their viability.
6. Include evidence preservation mechanisms for legal proceedings.
7. Establish periodic BCP testing and review procedures.

PS04 – Plan de Seguridad de Sistema

Class: Seguridad **Dependency:** PS02 **Standards:** ISO/IEC 27001, ISO/IEC 27002

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Relacion entre el Plan de Seguridad y los recursos asignados	PSC can justify resource availability and capacity for security mechanisms.
Relacion entre Plan de Seguridad y Evaluacion de Riesgos	Security procedures achieve the residual risk level from the risk assessment.
Relacion entre Plan de Seguridad y Politica de Seguridad	Security procedures achieve the objectives in the Security Policy.
Plan de Seguridad Mantenable	Plan includes procedures to maintain security over time against changes in threats, personnel, services, technology.
Relacion del Plan de Seguridad con las practicas y politica de certificacion	CPS and CP security objectives achieved through the Security Plan.
Requerimientos ISO 27002, secciones 6-12	Controls from ISO 27002 sections 6 through 12 are addressed: organizational security (6), asset management (7), HR security (8), physical security (9), communications management (10), access control (11),

Aspect	Evaluation
	systems acquisition/development/maintenance (12).
Administracion de llaves criptograficas	Security Plan includes a cryptographic key management plan for the full key lifecycle.
Proteccion del repositorio de acceso publico	Special protection measures for the public certificate repository.
Proteccion de informacion privada	Measures for protecting private information collected during registration.

Documentation required: Copy of the Information Security System Plan.

Goya Ledger status: :x: Missing

What needs to be done:

1. Write a comprehensive Information Security System Plan (SGSI Plan) covering ISO 27002 sections 5-12.
2. Map each ISO 27002 control to specific Goya implementations.
3. Include a cryptographic key management lifecycle section (generation, storage, backup, recovery, distribution, use, end-of-life, hardware lifecycle).
4. Document public repository protection measures.
5. Document private data protection measures for registration-phase data.
6. Cross-reference with PS01 (risk assessment), PS02 (security policy), CPS, and CP.
7. Include a maintenance procedure for keeping the plan current.

PS05 – Implementacion del Plan de Seguridad de Sistema

Class: Seguridad **Dependency:** PS03, PS04, ET01 **Standards:** ISO 27001, ISO 27002

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Relacion entre el Plan de Seguridad y los recursos asignados	PSC has resources and capacity to implement security mechanisms and procedures.
Relacion entre Plan de Seguridad y Politica de Seguridad	Implemented procedures achieve Security Policy objectives.
Relacion entre Plan de Seguridad y Evaluacion de Riesgos	Implemented procedures achieve residual risk from risk assessment.
Plan de Seguridad mantenible	Implementation includes procedures for ongoing security maintenance.
Relacion del Plan de Seguridad con practicas y politica de certificacion	CPS and CP security objectives achieved through implemented Security Plan.
Requerimientos ISO 27002, secciones 6-12	All ISO 27002 sections 6-12 controls are implemented (not just planned).

Aspect	Evaluation
Proteccion del repositorio de acceso publico	Implementation includes special measures for public repository protection.
Proteccion de informacion privada	Implementation includes private data protection during registration.

Documentation required: Descriptive document of the implementation of the Information Security System Plan.

Evidence required: Independent auditor report (auditoria en terreno).

Goya Ledger status: :x: Missing

What needs to be done:

1. Implement all controls defined in PS04.
2. Write an implementation description document showing how each planned control is deployed.
3. **Engage an independent auditor** to conduct an on-site audit verifying the implementation matches the plan. This is a hard requirement – no self-assessment is accepted.
4. The independent auditor must produce a formal report (informe de auditor independiente).
5. Demonstrate that implemented controls cover ISO 27002 sections 6-12 in practice.

PS06 – Plan de Administracion de Llaves

Class: Seguridad **Dependency:** PS02, PS04 **Standards:** ETSI TS 102 042, FIPS 140-2

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Relacion entre el Plan de Administracion de Llaves y los recursos asignados	Adequate resources and capacity for key management implementation.
Relacion entre Plan de Administracion de Llaves y Evaluacion de Riesgos	Key management procedures achieve the residual risk from risk assessment.
Plan de Administracion de Llaves mantenible	Procedures maintain key security over time against changes.
Relacion del Plan con practicas y politica de certificacion	CPS and CP security objectives achieved through key management implementation.
Requerimientos ETSI TS 102 042, seccion 7.2.1	CA key generation requirements considered.
Requerimientos ETSI TS 102 042, seccion 7.2.2	Key storage, backup, and recovery requirements considered.

Aspect	Evaluation
Requerimientos ETSI TS 102 042, seccion 7.2.3	CA public key distribution requirements considered.
Requerimientos ETSI TS 102 042, seccion 7.2.5	CA key usage requirements considered.
Requerimientos ETSI TS 102 042, seccion 7.2.6	CA key end-of-life requirements considered.
Requerimientos ETSI TS 102 042, seccion 7.2.7	Cryptographic hardware management requirements considered.
Nivel de seguridad del dispositivo seguro de los usuarios	User secure device meets FIPS 140-2 Level 3 (or Common Criteria EAL 3) minimum for cryptographic algorithm security and implementation.

Documentation required: Descriptive document of the key management plan implementation.

Evidence required: Independent auditor report (auditoria en terreno).

Goya Ledger status: :warning: Partial

- Goya has Ed25519 and ML-DSA-65 key management implemented in code.
- Key generation, storage, and signing are implemented in `crates/pqc_crypto_module/`.
- Algorithm selection aligned with BSI TR-02102-1 (2024): ML-DSA-65 “recommended”, Ed25519 “transitional”.
- Hybrid mode (classical + PQC signatures) deployed per ANSSI Avis PQC (2024) section 2.
- Formal Key Management Plan: PS06-KEY-MANAGEMENT-PLAN.md (completed).
- No HSM integration (keys are software-managed).
- No FIPS 140-2 certified cryptographic module.
- No independent auditor report.

What needs to be done:

1. Write a formal Key Management Plan document covering the full lifecycle per ETSI TS 102 042 Section 7.2:
 - CA key generation (ceremony procedures, multi-person control)
 - Key storage, backup, and recovery (HSM-based)
 - Public key distribution
 - Key usage controls and restrictions
 - Key end-of-life and destruction procedures
 - Cryptographic hardware lifecycle management
2. **Acquire an HSM** (Hardware Security Module) certified to FIPS 140-2 Level 3 or ISO/IEC 15408 (Common Criteria) EAL 3 minimum. This is mandatory for the CA signing keys.
3. Acquire FIPS 140-2 Level 3 (or CC EAL 3) user secure devices for subscriber key generation and storage.
4. Integrate HSM with the Goya CA module.
5. Engage an independent auditor to verify the key management implementation.

6. Document key ceremony procedures with multi-person control (m-of-n schemes).

PS07 – Gestion de Incidentes de Seguridad de la Informacion

Class: Seguridad **Dependency:** PS01 **Standards:** ISO/IEC 27002 Section 13

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Relacion entre el Plan de Gestion de Incidente y los recursos asignados	Adequate resources for implementing incident management associated with an ISMS.
Relacion entre Plan de Gestion de Incidentes y Politica de Seguridad	Procedures achieve Security Policy objectives.
Relacion entre Plan de Gestion de Incidentes y Evaluacion de Riesgos	Procedures achieve the residual risk from risk assessment.
Plan de Gestion de Incidentes mantenible	Procedures maintain security over time against changes.
Reporte de eventos (ISO 27002 Sec. 13.1.1)	Information security event reporting procedures.
Reporte de debilidades (ISO 27002 Sec. 13.1.2)	Security weakness reporting procedures.
Responsabilidades y procedimientos (ISO 27002 Sec. 13.2.1)	Incident management responsibilities and procedures.
Aprender de los incidentes (ISO 27002 Sec. 13.2.2)	Learning from security incidents.
Recoleccion de evidencia (ISO 27002 Sec. 13.2.3)	Evidence collection procedures.

Documentation required:

- Descriptive document of the information security incident management process
- Information Security Incident Management Plan
- Descriptive document of incident management system implementation
- Information Security Incident Reports

Evidence required: On-site audit.

Goya Ledger status: :warning: Partial

- Goya has docs/compliance/INCIDENT-RESPONSE-PLAN.md with incident classification and response procedures.
- Audit logging is implemented in the codebase.
- No formal ISO 27002 Section 13 alignment.
- No evidence collection procedures.

- No incident learning/review process documented.

What needs to be done:

1. Restructure the existing incident response plan to align with ISO 27002 Section 13 structure.
2. Add formal event reporting procedures (13.1.1).
3. Add security weakness reporting procedures (13.1.2).
4. Define incident management responsibilities and escalation procedures (13.2.1).
5. Add a post-incident learning process (13.2.2).
6. Add evidence collection and preservation procedures for potential legal proceedings (13.2.3).
7. Establish incident classification categories and severity levels.
8. Document contact points and communication channels for incident reporting.

ET01 – Evaluacion de la Plataforma Tecnologica

Class: Evaluacion Tecnologica **Dependency:** TB01, TB02, TB03, TB04, PS02, PS03, PS04, PS05 **Standards:** ETSI TS 102 042, FIPS 140-2, ISO/IEC 15408

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Modulo criptografico	Functionality (key generation 2048+ bit, signing/encryption), security (access controls for private key and crypto functions), lifecycle (backup/recovery), audit (log generation), documentation (manuals, contingency recovery).
Modulo AC (Autoridad Certificadora)	Functionality (certificate generation 2048+ bit, suspension/revocation, CRL generation, CRL dating, OCSP, FEA cert generation, secure AC-AR communication, X.500 directory delivery), security (access controls for cert generation and admin/audit), lifecycle (suspend/revoke certs, revoke root and generate new), audit (logs for contingency, authorized personnel, malicious access), documentation (operation manuals, contingency recovery).
Modulo AR (Autoridad de Registro)	Functionality (receive cert requests, request certs from CA), security (access controls), lifecycle (suspend/revoke), audit (logs), documentation (manuals, contingency recovery).
Modulo de Almacenamiento y Publicacion de Certificados	X.500 database storage, publication via LDAP v2.0 and/or OCSP V1.0.
Protocolos de comunicacion entre AR y AC	Secure certificate communication between AR and CA using industry-standard protocols.

Aspect	Evaluation
Elementos de administracion de log y auditoria	Log and audit modules to verify access attempts, successful/failed access, and malicious operations.

Documentation required: Descriptive document of the technological infrastructure implementation including: system interconnection diagrams, data network cabling, power cabling, auxiliary power, security devices, access control, and everything relevant to demonstrate infrastructure reliability. Hardware/software manufacturer manuals.

Evidence required: Manufacturer documentation certifying the security level, and/or external auditor reports.

Goya Ledger status: :x: Missing

What needs to be done:

1. **Acquire a FIPS 140-2 Level 3 certified HSM** (or ISO/IEC 15408 CC equivalent). No software-only crypto module will pass this requirement.
2. Build or configure a CA module that meets all functional requirements: X.509v3 cert generation with 2048+ bit keys, CRL generation, OCSP, suspension/revocation, role-based access control, audit logging.
3. Build or configure an RA (Registration Authority) module for receiving certificate requests and forwarding to the CA.
4. Implement certificate storage and publication via LDAP v2.0 and/or OCSP V1.0.
5. Implement secure communication protocols between RA and CA components.
6. Deploy comprehensive log and audit modules covering: access attempts, successful access, failed access, malicious operations.
7. Produce a full infrastructure documentation package: network diagrams, cabling, power, security devices, access control systems.
8. Obtain FIPS 140-2 or CC certification documentation from HSM manufacturer.
9. Produce operation manuals and contingency recovery procedures for each module.

SF01 – Seguridad Fisica

Class: Seguridad Fisica **Dependency:** PS02 **Standards:** ETSI TS 102 042 V2.1.2 Section 7.4.4, ISO/IEC 27002 Section 9

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Perimetro de seguridad fisica (ISO 27002, 9.1.1)	Physical security perimeter defined.
Controles de acceso fisico (ISO 27002, 9.1.2)	Physical access controls implemented.
Seguridad de oficinas, recintos e instalaciones (ISO 27002, 9.1.3)	Office and facility security.

Aspect	Evaluation
Proteccion contra amenazas externas y ambientales (ISO 27002, 9.1.4)	Protection against external/environmental threats.
Trabajo en areas seguras (ISO 27002, 9.1.5)	Secure area working procedures.
Areas de carga, despacho y acceso publico (ISO 27002, 9.1.6)	Delivery/loading/public access areas.
Ubicacion y proteccion de los equipos (ISO 27002, 9.2.1)	Equipment placement and protection.
Servicios de suministro (ISO 27002, 9.2.2)	Supporting utilities (power, etc.).
Seguridad del cableado (ISO 27002, 9.2.3)	Cabling security.
Mantenimiento de los equipos (ISO 27002, 9.2.4)	Equipment maintenance.
Seguridad de los equipos fuera de las instalaciones (ISO 27002, 9.2.5)	Off-premises equipment security.
Seguridad en la reutilizacion o eliminacion de los equipos (ISO 27002, 9.2.6)	Secure disposal/reuse.
Retiro de activos (ISO 27002, 9.2.7)	Asset removal controls.

Documentation required: Risk analysis, CP, CPS, System Security Plan, descriptive document of physical security implementation.

Evidence required: On-site audit of PSC facilities.

Goya Ledger status: :x: Missing

- Goya has docs/compliance/PHYSICAL-SECURITY.md but it is a policy framework, not an implementation description.
- Goya runs on Fly.io cloud infrastructure – no physical datacenter under Goya’s control.
- No physical security perimeter, access controls, or environmental protections that Goya manages directly.

What needs to be done:

1. **Establish a physical facility in Chile** (or contract a colocation/datacenter provider) where the HSM and CA infrastructure will reside. The evaluator conducts an on-site audit (“auditoria a las instalaciones del PSC”), so purely cloud-hosted infrastructure without a physical presence will not satisfy this requirement.
2. Alternative: Contract a Chilean datacenter that meets ISO 27002 Section 9 requirements and can demonstrate compliance during the audit. Document the shared responsibility model.

3. Implement or document (for contracted facilities): physical security perimeters, biometric/card access controls, CCTV, visitor logs, environmental controls (HVAC, fire suppression, water detection), UPS and generator backup, cable security, equipment maintenance procedures, secure equipment disposal procedures.
4. The HSM must reside in a physically secured area with multi-factor access control.
5. Write an implementation description document covering all 13 evaluation aspects from ISO 27002 Section 9.

PO01 – Politica de Certificados de Firma Electronica Avanzada

Class: Politica del PSC **Dependency:** TB01, TB02, TB03, TB04, PS03, PS05, PS06, ET01, SF01 **Standards:** ETSI TS 102 042, RFC 3647

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Titulares	Who can be issued an FEA certificate.
Procedimiento de registro	Holder registration, identity verification, and authentication.
Usos del certificado	Purposes for which the certificate is issued and its limitations.
Obligaciones CA, RA, titular y receptor	Obligations of all parties in the certificate lifecycle.
Declaracion de las garantias, seguros y responsabilidades	Guarantees, insurance, and liabilities of the parties.
Privacidad y Proteccion de los datos	Data privacy and protection policies, appropriate for FEA, published and known to subscribers.
Suspension y revocacion del certificado	Under what circumstances certificates are suspended/revoked and who can request these actions.

Documentation required: Document containing the FEA Certificate Policy.

Evidence required: On-site audit.

Goya Ledger status: :x: Missing

What needs to be done:

1. Write a formal FEA Certificate Policy (CP) document following RFC 3647 structure and ETSI TS 102 042 requirements.
2. Define certificate types and who can be issued FEA certificates (natural persons, legal persons, representatives).
3. Define the registration process including identity verification (presencial or remote with equivalent assurance).
4. Define certificate uses and limitations.
5. Define obligations for: CA, RA, certificate holder, relying parties.

6. Define guarantees, insurance coverage, and liability limits.
 7. Define privacy and data protection policies specific to FEA.
 8. Define suspension and revocation circumstances and authorized requestors.
 9. Cross-reference with CPS, security policy, risk assessment, and key management plan.
 10. Have the CP reviewed for compliance with Chilean consumer protection and data protection law.
-

PO02 – Declaracion de Practicas de Certificacion (CPS)

Class: Politica del PSC **Dependency:** PO01, AD01, AD02, PE02 **Standards:** ETSI TS 102 042, RFC 3647

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Verificar estructura	CPS contains at least the topics indicated in Ley N 19.799 and Reglamento Art. 6.
Existencia del documento de practicas de certificacion	Documentation exists and is duly published.
Obligaciones y responsabilidades del PSC	Declaration of PSC obligations and duties.
Confidencialidad de la informacion de los solicitantes / proteccion de datos	Procedures for protecting applicant information.
Obligaciones y responsabilidades del titular	Definitions of user/applicant duties and obligations.
Ciclo de vida de los certificados	Procedures defining certificate lifecycle: issuance, revocation, suspension, expiration, renewal.
Ciclo de vida del PSC	Procedures for PSC cessation, transfer to another PSC, ongoing service continuity.
Controles de Seguridad tecnica	Technical security measures for protecting signing data creation.
Controles de seguridad no tecnica	Non-technical security controls for certificate generation, authentication, issuance, suspension, revocation, audit, and information storage.

Documentation required: CPS document.

Evidence required: On-site audit.

Goya Ledger status: :warning: Partial

- Goya has docs/policy/CPS.md and a published HTML version at docs/deploy/cps.html.
- The existing CPS was written for the DID/VC model, not for X.509 FEA certificates.
- The CPS likely does not follow RFC 3647 structure.

- Missing: PSC lifecycle (cessation/transfer), non-technical security controls, specific FEA certificate lifecycle procedures.

What needs to be done:

1. Rewrite the CPS following RFC 3647 structure (9 sections: Introduction, Publication and Repository Responsibilities, Identification and Authentication, Certificate Lifecycle Operational Requirements, Facility/Management/Operations Controls, Technical Security Controls, Certificate/CRL/OCSP Profiles, Compliance Audit, Other Business and Legal Matters).
2. Align all content with X.509 FEA certificate issuance (not DID/VC).
3. Include all mandatory topics from Ley N 19.799 and Reglamento Art. 6.
4. Define PSC lifecycle procedures including voluntary cessation and certificate transfer.
5. Publish the updated CPS on the public website.
6. Ensure consistency with the CP (PO01) and security policy (PS02).

PO03 – Modelo Operacional de la Autoridad Certificadora

Class: Politica del PSC **Dependency:** PO02 **Standards:** N/A

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Consistencia del documento	Document includes all parts described in the guide's annexes.
Resumen Ejecutivo	Executive summary with: coherent content summary, company history, commercial relationships with service providers.
Componentes del sistema	System components covering: RA interfaces, security element implementation, administration processes, certificate directory system, audit and backup processes, databases, privacy, personnel training.
Proceso de Certificacion	Model considers key generation for the holder per certification policies.
Plan de Auditoria	Audit plan covering: security devices, personnel restrictions, administration interfaces, disaster recovery procedures, backup procedures.
Seguridad	Security requirements covering: physical installation security, personnel security, cryptographic module security level.

Documentation required: Description of the CA operational model.

Evidence required: On-site audit.

Goya Ledger status: :x: Missing

What needs to be done:

1. Write a CA Operational Model document answering:
 - What services does the CA provide?
 - How do the different services interrelate?
 - Where will the CA operate (physical locations)?
 - What types of certificates will be issued?
 - How will services be delivered, including externalized services?
 - How will assets be protected?
 2. Include detailed sections on: system components, RA interfaces, security implementation, administration processes, certificate directory, audit and backup, databases, privacy, and personnel training.
 3. Describe the certification process including key generation for certificate holders.
 4. Include an audit plan covering security devices, personnel, administration, disaster recovery, and backup.
 5. Include security requirements for physical installations, personnel, and cryptographic modules.
-

PO04 – Modelo Operacional de la Autoridad de Registro (AR)

Class: Politica del PSC **Dependency:** PO03 **Standards:** ETSI TS 102 042

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Consistencia del documento	Document includes all parts described in the guide's annexes.
Resumen Ejecutivo	Executive summary coherent with document content.
Componentes del sistema	System components covering: CA interfaces, security device implementation, administration processes, audit and backup, databases, privacy, personnel training.
Proceso de Certificacion	Registration model provides unique holder identification and private key usage model that provides required system confidence.
Plan de Auditoria	Audit plan covering: security devices, security, personnel restrictions, administration interfaces, disaster recovery, backup.
Seguridad	RA model includes: physical installation security description, personnel security.

Documentation required: Description of the RA operational model. Technical manual of FEA secure signing devices.

Evidence required: On-site audit.

Goya Ledger status: :x: Missing

What needs to be done:

1. Write an RA Operational Model document covering:
 - RA services (certificate requests, identity verification, device provisioning)
 - RA locations and operation points
 - Types of certificates handled
 - How externalized services are managed
 2. Include: CA interfaces, security device implementation, administration processes, audit/backup, databases, privacy, personnel training.
 3. Describe the registration and identity verification process with unique holder identification.
 4. Describe secure signing device delivery and provisioning procedures per ETSI TS 102 042 (Art. 25 of Reglamento).
 5. Include an audit plan and security section.
 6. Produce a technical manual for the FEA secure signing devices used by subscribers.
-

AD01 – Manual de Operaciones de la Autoridad Certificadora

Class: Administracion **Dependency:** PS04 **Standards:** ETSI TS 102 042, RFC 3647

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Nomina y descripcion de cargos	Personnel roster with job descriptions, responsibilities, and procedures.
Referencias de los cargos en los planes de la PSC	Personnel referenced in business continuity and disaster recovery plans.
Planes de Contingencia	Description of contingency plans.
Descripcion de las operaciones	Detailed procedures for: key pair generation, CRL publication, certificate information publication, key and certificate distribution, certificate renewal, post-revocation renewal, access control measures, backup and recovery procedures.
Actualizacion de CPS y CP	Procedure for updating CPS and CP.
Servicios de la AC	Description of CA services.
Interaccion AC - AR	Document covers AC-AR interaction.

Documentation required: CA Operations Manual.

Evidence required: On-site audit.

Goya Ledger status: :x: Missing

What needs to be done:

1. Write a CA Operations Manual with:
 - Personnel roster, job descriptions, responsibilities, and operational procedures
 - Personnel roles in BCP/DRP
 - Contingency plans
 - Detailed operational procedures for every CA function (key generation, CRL publication, certificate information publication, key/certificate distribution, renewal, post-revocation renewal, access control, backup/recovery)
 - CPS and CP update procedures
 - Description of all CA services
 - CA-RA interaction procedures
 2. Use diagrams, flowcharts, and timelines for clarity per the guide's recommendation.
 3. Ensure consistency with the Certification Policy (PO01) and CPS (PO02).
-

AD02 – Manual de Operaciones de la Autoridad de Registro

Class: Administracion **Dependency:** PS04 **Standards:** RFC 3647

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Nomina y descripcion de cargos	Personnel roster with job descriptions and operational procedures.
Procedimiento de registro	Holder registration, identity authentication and verification.
Entrega segura de los datos de creacion de firma	Procedures for secure personal delivery of signing data creation material to certificate holders.
Dispositivo seguro y mecanismos de firma del titular	Procedures ensuring signing data creation material, once delivered, is solely under the holder's control. Secure device must sign internally without exposing the private key. Access control mechanism known only to the holder, modifiable by holder, with lockout after repeated failed attempts. PSC must provide tools and instructions for secure signing.
Capacitacion y servicio al titular	Training procedures for holders to use signing devices securely. Customer service for questions and issues.
Referencias de los cargos en los planes del PSC	Personnel referenced in BCP/DRP.
Planes de Contingencia	Emergency plans.
Descripcion de las operaciones	Detailed procedures for: secure certificate suspension/revocation, access control, backup/recovery.

Aspect	Evaluation
Interaccion entre AR y PSC	Document covers AR-CA interaction procedures.

Documentation required: RA Operations Manual. Technical manual for FEA secure signing devices.

Evidence required: On-site audit.

Goya Ledger status: :x: Missing

What needs to be done:

1. Write an RA Operations Manual with:
 - Personnel roster and job descriptions
 - Detailed registration procedures (identity verification, document requirements)
 - Secure delivery procedures for signing keys/devices
 - Secure device management procedures (PIN/password setup, lockout mechanisms)
 - Holder training procedures and customer service plan
 - Personnel roles in BCP/DRP
 - Contingency plans
 - Operational procedures for suspension, revocation, access control, backup/recovery
 - AR-CA interaction procedures
2. Write a technical manual for the FEA secure signing devices.
3. Ensure consistency with the certification policies and CPS.

PE01 – Examen del Personal

Class: Examen del Personal **Dependency:** PS02 **Standards:** ISO 27002, ETSI TS 102 042

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Antecedentes profesionales del personal critico	Professional background and experience of critical personnel verified against job profiles and risk analysis.
Capacitacion del personal critico en aspectos de seguridad	Critical personnel trained in security practices relevant to their role and function.
Antecedentes comerciales del personal critico	Commercial background verification of critical personnel.
Antecedentes penales del personal critico	Criminal background verification of critical personnel.
Procedimiento de contratacion del personal critico	Defined hiring procedure for critical personnel.

Aspect	Evaluation
Procedimiento de verificación de antecedentes del personal crítico	Defined procedure for verifying backgrounds of selected critical personnel.

Documentation required: Job profiles for positions handling sensitive information or systems. CVs of personnel in sensitive positions. Security procedures applied in hiring and monitoring of commercial/criminal backgrounds.

Evidence required: Identification of critical personnel during evaluator's on-site visit (RUT, photo, fingerprint, etc.).

Goya Ledger status: :x: Missing

What needs to be done:

1. Define "critical personnel" profiles per risk analysis: CA operators, RA operators, security officers, system administrators, anyone with access to signing keys or sensitive data.
2. Establish hiring procedures for critical personnel including:
 - Professional qualification requirements
 - Minimum experience requirements
 - Commercial background checks
 - Criminal background checks (certificado de antecedentes penales)
 - Background checks completed before granting access to sensitive systems
3. Establish confidentiality contracts that extend beyond employment termination.
4. Define security training programs for each critical role.
5. Document all of the above and prepare CVs and background verification records.
6. Ensure critical personnel are staff (personal de planta), not exclusively contractors, for sensitive roles.

PE02 – Examen del Personal – Oficial de Seguridad

Class: Examen del Personal **Dependency:** PS02 **Standards:** N/A (no specific standard, but Ley N 19.799 Art. 17 c)

What the Entidad Acreditadora evaluates:

Aspect	Evaluation
Antecedentes profesionales del OS	Professional and curricular background of the Security Officer (IT Security Manager) presented by the PSC.
Antecedentes comerciales del OS	Commercial background of the Security Officer.
Antecedentes penales del OS	Criminal background of the Security Officer.
Procedimiento de contratación del OS	Defined hiring procedure for the Security Officer.
Procedimiento de verificación de antecedentes del OS	Defined procedure for verifying the Security Officer's backgrounds.

Documentation required:

- CV of the Security Officer including references
- Security procedures applied in hiring the Security Officer and verification of commercial/criminal backgrounds

Evidence required: Professional certificates from recognized entities or those homologated by the Ministry of Education or industry references. Commercial background certificate. Criminal background certificate. Interview with the Security Officer.

Goya Ledger status: :x: Missing

What needs to be done:

1. **Hire a Security Officer (Oficial de Seguridad)** who meets the following minimum requirements:
 - Professional qualification in IT security (logical and physical). Recommended profile: Computer Engineer or equivalent.
 - Certification and/or minimum 5 years of experience in information security.
 - No criminal or commercial disqualifications (antecedentes penales o comerciales).
 2. The Security Officer is responsible for: designing, implementing, and overseeing security procedures and practices at the PSC facilities.
 3. Establish contractual confidentiality obligations that extend beyond employment termination.
 4. Document the hiring procedure, background verification procedure, and all supporting certificates.
 5. Prepare for the evaluator to conduct an interview with the Security Officer during the on-site audit.
-

Critical Path and Priority Order

The dependency chain means requirements must be addressed in a specific order. The recommended execution sequence:

Phase 1: Legal Foundation (Months 1-3)

1. **AS01** – Constitute Chilean SpA, obtain RUT, appoint representante legal
2. **LE01** – Complete legal documentation, privacy policy, subscriber contracts
3. **PS01** – Conduct formal risk assessment with independent external entity

Phase 2: Security Framework (Months 3-6)

1. **PS02** – Write Information Security Policy
2. **PE02** – Hire Security Officer
3. **PE01** – Define critical personnel profiles, hiring procedures
4. **PS07** – Write incident management plan aligned with ISO 27002 Section 13
5. **PS04** – Write Information Security System Plan (SGSI)
6. **PS03** – Expand BCP/DRP per ISO 27002 Section 14 and ETSI TS 102 042

Phase 3: Technical Infrastructure (Months 6-12)

1. **TB01** – Implement X.509v3 certificate issuance module
2. **TB02** – Implement CRL generation and validate OCSP conformance
3. **TB03** – Build public certificate registry website with 99% SLA
4. **TB04** – Define trust model and implement TSL per ETSI TS 102 231
5. **PS06** – Acquire HSM, write key management plan
6. **SF01** – Establish or contract physical facility in Chile

Phase 4: Operations and Documentation (Months 12-15)

1. **ET01** – Platform technology evaluation and documentation
2. **PS05** – Independent auditor report on security implementation
3. **PO01** – Write FEA Certificate Policy per RFC 3647
4. **PO02** – Rewrite CPS per RFC 3647 for X.509 FEA
5. **PO03** – Write CA Operational Model
6. **PO04** – Write RA Operational Model
7. **AD01** – Write CA Operations Manual
8. **AD02** – Write RA Operations Manual

Phase 5: Application (Month 15-16)

1. **RG01** – Prepare internal inspection procedures, submit application with 798 UF fee, obtain civil liability insurance (5,000 UF) after favorable evaluation

Cost Estimates

Item	Estimated Cost
SpA constitution and legal setup	CLP \$2-5M
Accreditation fee (798 UF)	CLP \$28M
Civil liability insurance (5,000 UF/year)	CLP \$15-25M/year
HSM (FIPS 140-2 Level 3)	USD \$15-50K
Secure signing devices for subscribers	USD \$20-50/device
Physical facility or colocation in Chile	CLP \$3-8M/month
Security Officer salary	CLP \$3-5M/month
Independent security auditor	CLP \$15-30M
	CLP \$10-20M

Item	Estimated Cost
ISO 27001 preparation consultant	
Total estimated pre-accreditation cost	CLP \$100-200M (USD \$100-200K)

Architectural Gap Analysis

The single largest gap is the absence of X.509v3 certificate issuance. Goya's current architecture is built on DID + SD-JWT Verifiable Credentials, which is a modern approach but incompatible with the Chilean PSC framework's explicit requirement for X.509v3 certificates per ISO/IEC 9594-8.

Options

Option A: Build a parallel X.509 CA module alongside the existing DID/VC system. - Goya retains its blockchain/DID architecture for non-Chilean use cases. - A new CA module issues X.509v3 FEA certificates for Chilean accreditation. - Shared infrastructure: HSM, key management, audit logging, OCSP. - Estimated development: 3-6 months.

Option B: Partner with an existing accredited PSC and operate as a technology provider. - Goya provides the technology platform; the partner holds the PSC accreditation. - Avoids the need for Chilean SpA, physical facility, and full documentation package. - Loses direct control over the accreditation and revenue share.

Option C: Pursue accreditation through ETSI/eIDAS mutual recognition (future). - Chile and the EU have discussed mutual recognition frameworks. - Not currently available. High regulatory uncertainty. - Goya's Estonian entity and ETSI-aligned architecture would be advantageous if this path opens.

Recommended: Option A. Build the X.509 CA module. The existing crates/ `pgc_crypto_module/` and OCSP implementation provide a foundation. The DID/VC system continues to operate for non-PSC use cases.